INF1416
Segurança da Informação

Prof. Anderson Oliveira da Silva
D. Sc. Ciências em Informática
Engenheiro de Computação
anderson@inf.puc-rio.br

Departamento de Informática
PUC-Rio

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Ementa

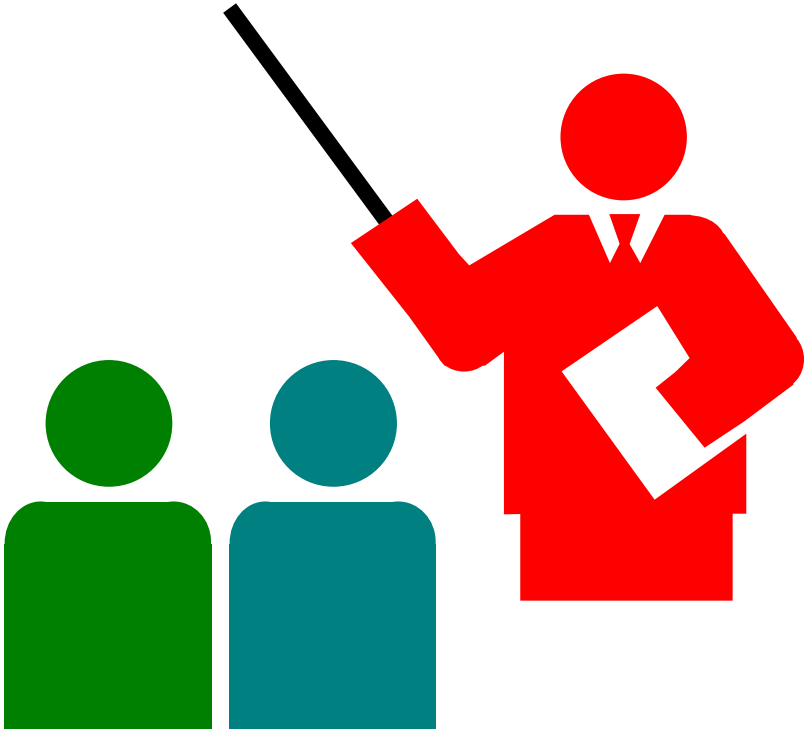
- Segurança da Informação
  Prof. Anderson O. da Silva

Visão Geral da Segurança da Informação:

- Proteção da Informação
- Papéis e Responsabilidades
- Ameaças Comuns
- Gerenciamento de Risco
- Classificação da Informação
- Políticas e Procedimentos

Visão Geral de Segurança da Informação

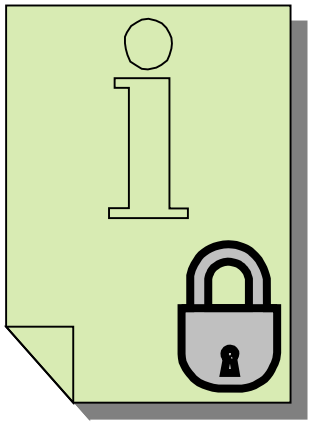
- Segurança da Informação
  Prof. Anderson O. da Silva



Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

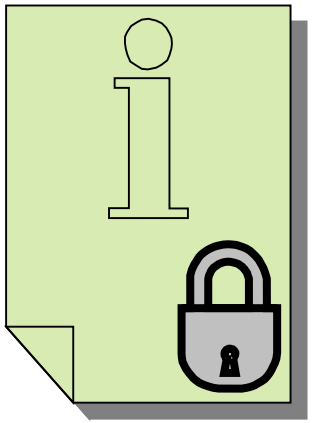
(Thomas R. Peltier, 2001)



Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)

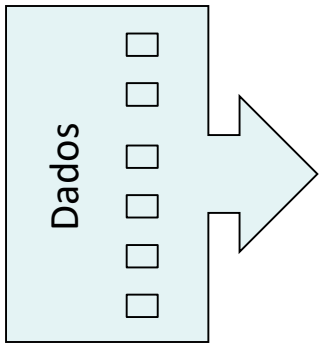


- **Por que os recursos de informação são valiosos para uma empresa?**

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **As empresas diariamente produzem uma enorme quantidade de dados...**



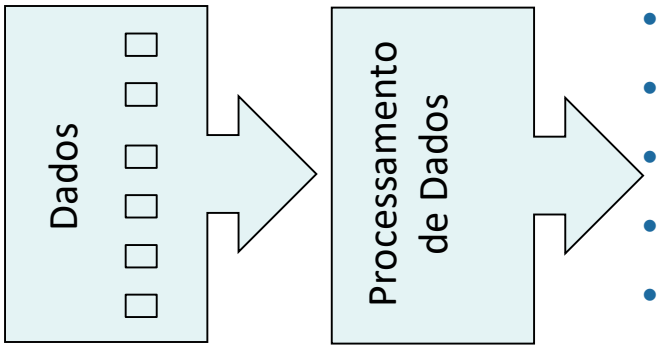
matéria-prima

- **Dados são elementos básicos, sem contexto ou significado específico, que podem ser quantificados, medidos ou observados.**
  - **Números: 55, 21, 3527, 1500, 225, 3, 15.000, ...**
  - **Palavras: Anderson, Silva, Marquês, São, Vicente, Brasil, Rio, Janeiro, PUC, INF, Gávea, Rua, ...**
  - **Símbolos: $, %, #, @, &, ...**

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **...que servem como matéria-prima para o processamento de dados...**



matéria-prima

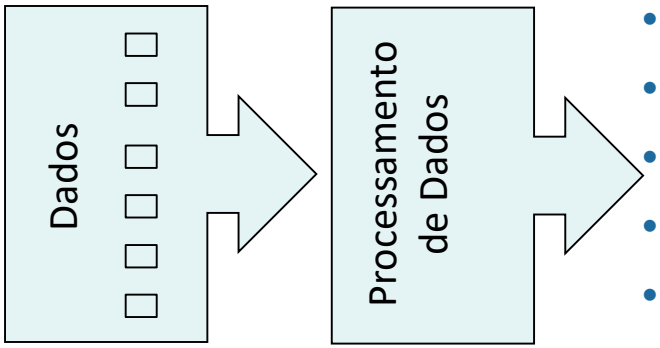
organização ou estruturação dos dados

- **Nome: Anderson da Silva**
- **Idade: 55**
- **Telefone: 21 3527-1500**
- **Local: Rua Marquês de São Vicente, 225**
- **Bairro: Gávea**
- **Cidade: Rio de Janeiro**
- **Empresa: PUC-Rio**
- **Departamento: INF**
- **E-mail: anderson@inf.puc-rio.br**
- **Salário-base: R$ 15.000,00**
- **Anuênio: 3,0%**

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **...que servem como matéria-prima para o processamento de dados...**



matéria-prima

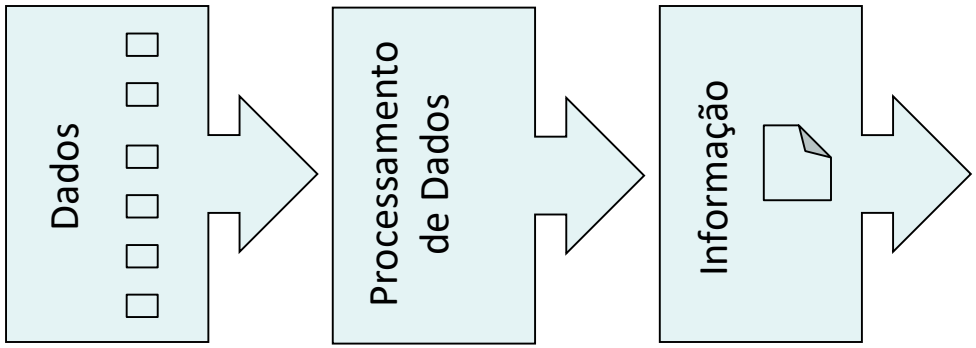
organização ou estruturação dos dados

- **Exportador: Anderson & Silva**
- **Código do item: 55-21-3527**
- **Quantidade: 1500**
- **Destino: Rua Marquês de São Vicente, 225**
- **Bairro: Gávea**
- **Cidade: Rio de Janeiro**
- **Importador: PUC-Rio**
- **Departamento: INF**
- **E-mail: anderson@inf.puc-rio.br**
- **Valor do item: R$ 15.000,00**
- **Taxa de frete: 3,0%**

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **...que produz informação (produto intermediário)...**



matéria-prima

organização ou estruturação dos dados

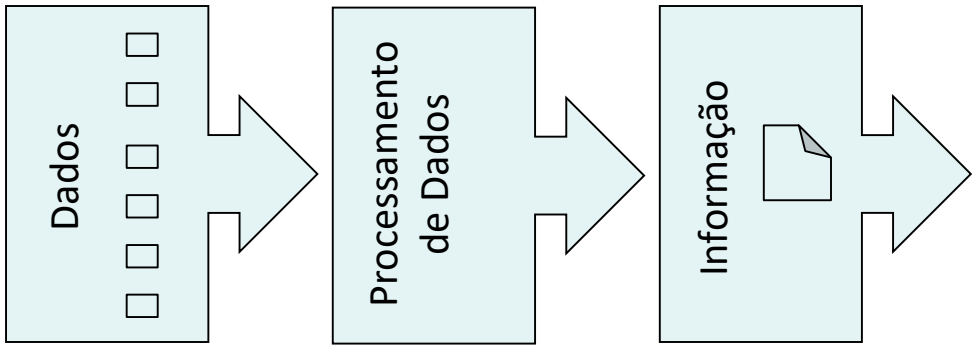
produto intermediário

- **Informação de identificação pessoal**
  - Nome: Anderson da Silva
  - Idade: 55
  - Telefone: 21 3527-1500
  - Local: Rua Marquês de São Vicente, 225
  - Bairro: Gávea
  - Cidade: Rio de Janeiro
  - Empresa: PUC-Rio
  - Departamento: INF
  - E-mail: anderson@inf.puc-rio.br
  - Salário-base: R$ 15.000,00
  - Anuênio: 3,0%

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **...que produz informação (produto intermediário)...**



matéria-prima

organização ou estruturação dos dados

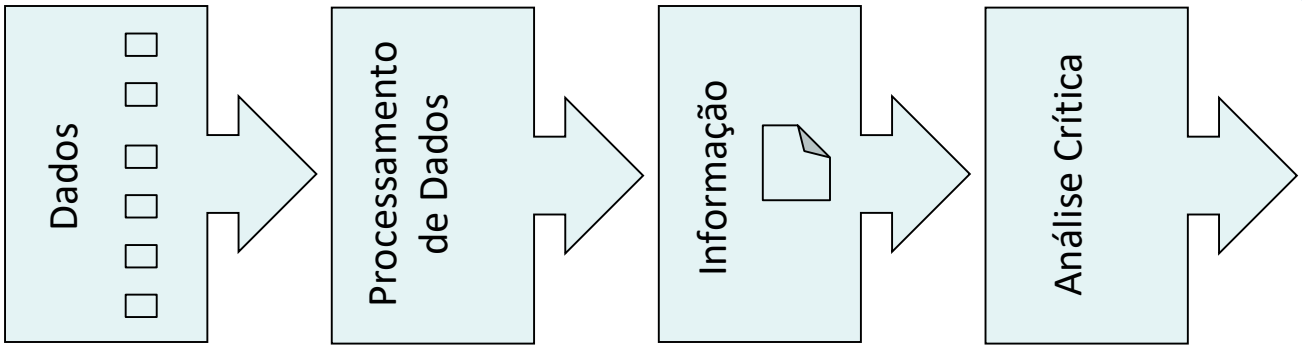
produto intermediário

- **Informação de importação de produto**
  - Exportador: Anderson & Silva
  - Código do item: 55-21-3527
  - Quantidade: 1500
  - Destino: Marquês de São Vicente, 225
  - Bairro: Gávea
  - Cidade: Rio de Janeiro
  - Empregador: PUC-Rio
  - Departamento: INF
  - Importador: anderson@inf.puc-rio.br
  - Valor do item: R$ 15.000,00
  - Taxa de frete: 3,0%

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **Quando realizamos a análise crítica da informação num determinado contexto...**



matéria-prima

organização ou estruturação dos dados

produto intermediário

tratamento da informação em determinado contexto

- **Existem funcionários bem avaliados com salário inferior à média do mercado?**



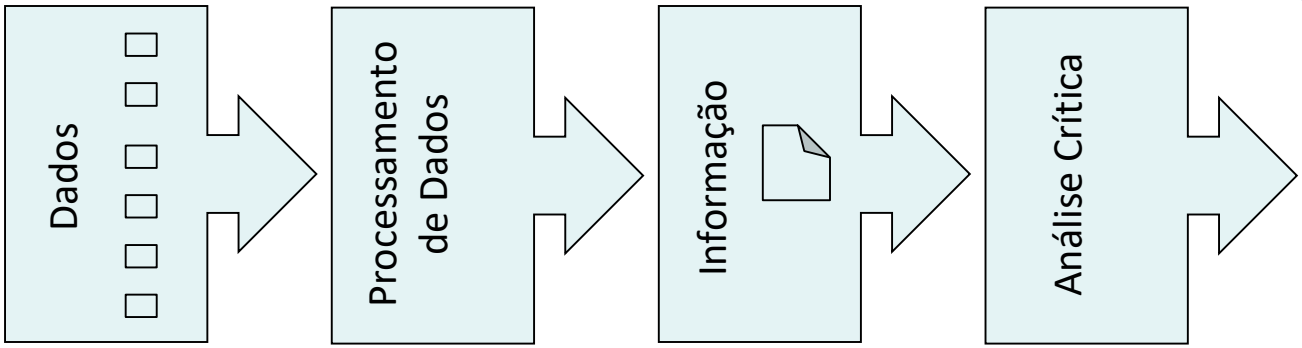
DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **Quando realizamos a análise crítica da informação num determinado contexto...**



matéria-prima

organização ou estruturação dos dados

produto intermediário

tratamento da informação em determinado contexto

- **Quais são as opções de importação que podem reduzir a taxa de frete para o cliente?**



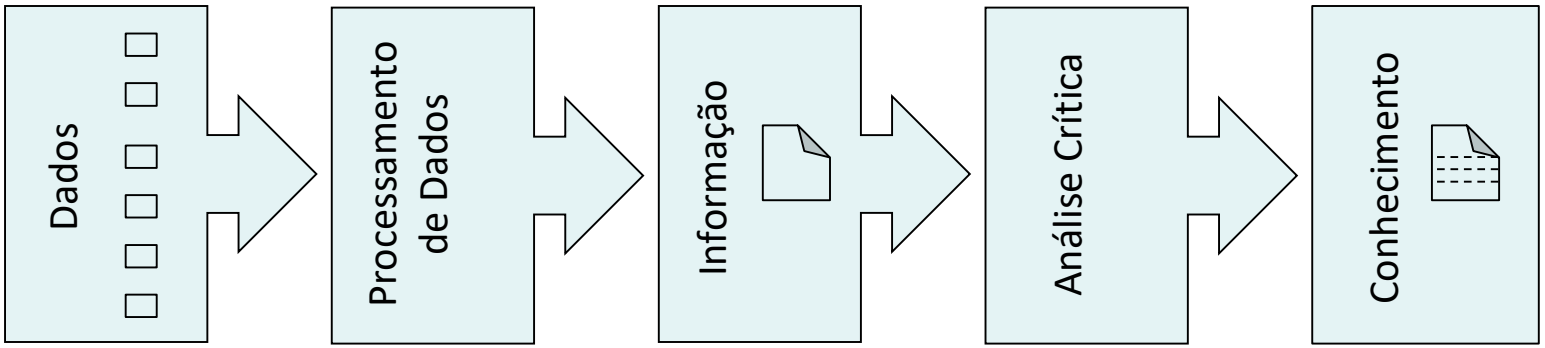
DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Dados x Informação x Conhecimento

Precisamos entender a diferença e a relação entre dados, informação e conhecimento...

- **...produzimos conhecimento.**



matéria-prima

organização ou estruturação dos dados

produto intermediário

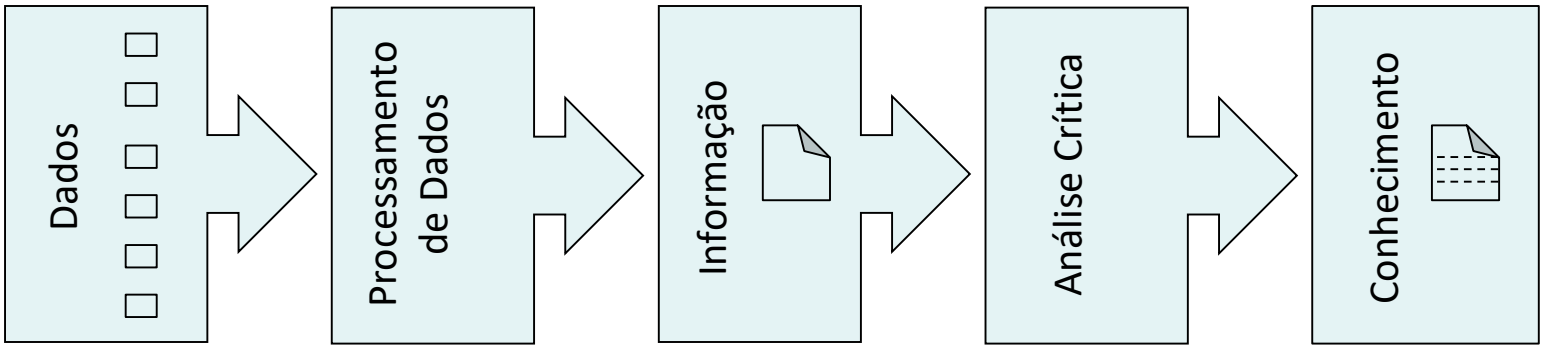
tratamento da informação em determinado contexto

produto final

Valor dos ativos de informação

Por que os ativos de informação são valiosos para uma empresa?

- **Informação e conhecimento são fundamentais para a tomada de decisão e resolução de problemas.**



matéria-prima

organização ou estruturação dos dados

produto intermediário

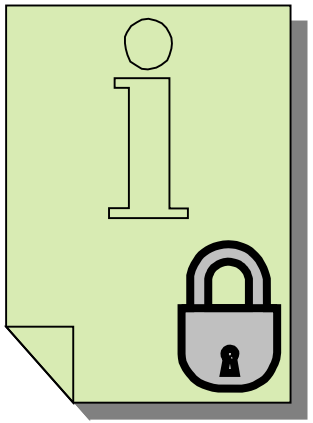
tratamento da informação em determinado contexto

produto final

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)

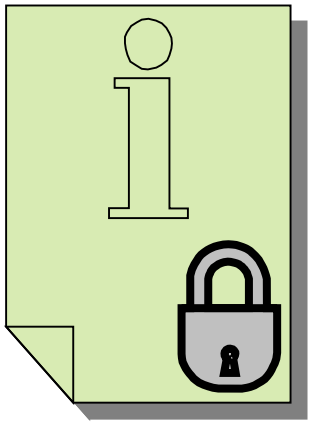


- **Por que os recursos de informação são valiosos para uma empresa?**
  - **Informação e conhecimento são fundamentais para a tomada de decisão e resolução de problemas.**

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)

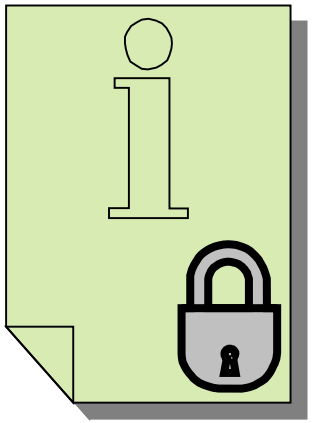


- **Como identificar os valiosos recursos de informação de uma empresa?**

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)

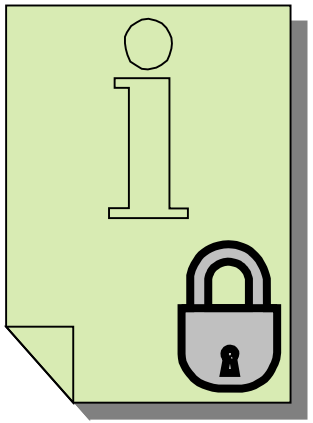


- Como identificar os **valiosos recursos de informação** de uma empresa?
- Como assegurar a **seleção e aplicação de salvaguardas** apropriadas?

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)



- Como identificar os valiosos recursos de informação de uma empresa?
- Como assegurar a seleção e aplicação de salvaguardas apropriadas?
- Como assegurar que as decisões tomadas ajudarão a atingir o objetivo do negócio ou a sua missão?

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.



- Como identificar os **informação** de uma
- Como assegurar a **seleção e aplicação de salvaguardas** apropriadas?
- Como assegurar que as decisões tomadas ajudarão a atingir o objetivo do negócio ou a sua missão?

Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.



Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.



- Segurança da Informação, Segurança Cibernética e Proteção à Privacidade
  - LGDP e Marco Civil da Internet
  - Família ISO 27000
  - ISO 29100 e ISO 29134
  - ISO 22301 e ISO 22313
  - Série NIST SP-800

Compliance

Compliance é o ato de estar em conformidade com leis, regulamentos, normas e padrões éticos, tanto internos quanto externos, de uma organização.



- Segurança da Informação, Segurança Cibernética e Proteção à Privacidade
  - ABNT NBR ISO/IEC 27001
  - ABNT NBR ISO/IEC 27002
  - ABNT NBR ISO/IEC 29100
  - ABNT NBR ISO/IEC 27701

Pontos-chaves

Ativos de informação estão sujeitos a ameaças de perda, roubo ou danos.

- Os ativos de informação precisam ser **protegidos** para assegurar a **confidencialidade**, **integridade** e **disponibilidade**, evitando **danos** e **prejuízos** à organização.

- Quando entendemos o **valor da informação** para uma organização, compreendemos a necessidade da **segurança da informação** e da **cibersegurança**.

Pontos-chaves

Ativos de informação estão sujeitos a ameaças de perda, roubo ou danos.

- **A segurança da informação visa garantir a proteção dos ativos através da seleção e aplicação de salvaguardas apropriadas e alinhadas com o objetivo do negócio e a missão da organização.**

- **A cibersegurança visa garantir a proteção dos ativos contra as ameaças cibernéticas mantendo um nível aceitável de estabilidade, continuidade e segurança.**

Pontos-chaves

Informações de identificação pessoal (dados pessoais) devem ser protegidos para assegurar a proteção da privacidade das pessoas.

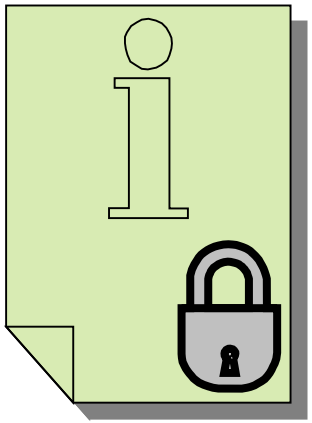
- **A proteção da privacidade visa garantir a conformidade da organização com os direitos fundamentais de privacidade dos titulares de dados pessoais (DP), conforme estabelecido pela Lei Geral de Proteção de Dados Pessoais (LGPD).**

- **A violação da privacidade é a situação onde os dados pessoais são tratados em violação de um ou mais requisitos pertinentes de salvaguarda da privacidade.**

Proteção da Informação

Proteger os valiosos recursos de informação de uma empresa através da seleção e aplicação de salvaguardas apropriadas, ajudando a atingir o objetivo do negócio ou a sua missão.

(Thomas R. Peltier, 2001)



- Proteger recursos de informação
  - Mídias, hardware e software.
- Selecionar e aplicar salvaguardas
  - Políticas, padrões e procedimentos.
- Ajudar a atingir o objetivo do negócio ou a sua missão
  - Através da proteção dos ativos.

Proteção da Informação

Baseada em oito elementos principais:

1. Auxiliar nos objetivos do negócio ou na missão da empresa;
2. Integrar deveres e obrigações;
3. Ter custo efetivo;
4. Explicitar responsabilidades;
5. Garantir acesso apenas a pessoas autorizadas;
6. Requer uma abordagem compreensiva e integrada;
7. Ser periodicamente reavaliada;
8. Ser adaptável para várias localidades.

Fonte: Information Security Policies, Procedures and Standards – Guidelines for Effective Information Security Management, Thomas R. Peltier – Auerbach

Proteção da Informação

1 - Auxiliar nos objetivos do negócio ou na missão da empresa:

- **Proteção para proteger, não para inviabilizar o negócio ou a missão da empresa.**

- **A posição do ISSO (Information Systems Security Officer) ou CISO (Chief Information Security Officer) foi criada para auxiliar a empresa, e não o contrário.**

Proteção da Informação

2 – Integrar deveres e obrigações:

- **Dever de lealdade**
  - **Decisões devem ser tomadas no melhor interesse da empresa.**
- **Dever de Preservação**
  - **Obrigação de proteger os ativos da empresa.**
- **Um programa de proteção efetivo auxilia a gerência sênior nos deveres e obrigações.**

Proteção da Informação

3 – Ter custo efetivo:

- Controles implantados por decreto (imposição não justificada) são contrários ao clima do negócio.
- **Antes de propor um controle, é necessário confirmar que existe um risco significativo.**
- Processo de análise de riscos deve ser executado para identificar os riscos e, então, propor os controles apropriados.

Proteção da Informação

4 – Explicitar responsabilidades:

- Para ser efetivo, um programa de proteção deve publicar:
  - Política de Segurança da Informação (PSI);
  - Missão do Grupo de Proteção da Informação.
- **A política deve identificar os papéis e responsabilidades de todos os funcionários.**
- A política deve ser incorporada em todos os contratos de serviços de pessoas.

Proteção da Informação

5 – Garantir acesso apenas a pessoas autorizadas:

- Acesso a informação é feito, muitas vezes, fora da unidade ou da empresa, sob responsabilidade do proprietário da informação.

- A principal responsabilidade é do monitoramento da utilização do sistema para certificar que o mesmo está em conformidade com o nível de autorização permitido ao usuário.

- A tela inicial do sistema deve indicar que controles de monitoramento serão utilizados durante o acesso.

Proteção da Informação

6 – Requer uma abordagem compreensiva e integrada:

- **Questões de proteção da informação devem fazer parte do ciclo de vida do desenvolvimento de um sistema.**

- **Durante a fase inicial ou de análise, a proteção da informação deve incluir:**
  - **Análise de risco;**
  - **Análise de impacto no negócio;**
  - **Classificação da informação.**

- **Como cada um dos departamentos gera informação, deve ser designado um responsável pela proteção da informação em cada um deles.**

Proteção da Informação

7 – Ser periodicamente reavaliada:

- Como o tempo muda necessidades e objetivos, um programa de proteção da informação deve se auto-examinar regularmente para fazer mudanças sempre que necessário.

- **Esse processo é dinâmico e deve ocorrer pelo menos a cada 18 meses.**

Proteção da Informação

8 – Ser adaptável para várias localidades:

- **O programa de proteção da informação deve ser implementado em toda empresa, porém, é importante permitir que unidades tenham abertura para fazer modificações dentro de suas necessidades.**

- **Organizações multinacionais geralmente precisam fazer ajustes para os pontos de presença localizados em vários países.**

Proteção da Informação

Considerações Importantes:

- **No negócio, um programa de proteção de informação efetivo é secundário com relação à necessidade de se ter resultado.**
- **No setor público, o mesmo ocorre com relação aos serviços que a agência deve prover.**
- **O custo dos controles não deve exceder os benefícios esperados.**
- **Os controles devem ser apropriados e proporcionais.**

Proteção da Informação

Mais que apenas segurança de computadores.

- **Um programa de segurança da informação efetivo vai além da área de tecnologia da informação (TI) .**
- **Grande parte da informação disponível ainda se encontra impressa.**
- **Cada estágio do ciclo de vida do ativo informação, da criação à sua eventual destruição, deve ser acompanhado.**
- **A Política de Segurança da Informação deve fazer parte das políticas da empresa e não deve ser originada na área de TI.**

Papéis e Responsabilidades

. Corporate Information Officer (CIO)

- Sua função é estabelecida pela gerência sênior da organização;
- Deve comandar a gerência dos ativos de informação da organização;
- Deve coordenar o trabalho do **Profissional de Segurança da Informação** e do **Administrador de Segurança Física**, responsáveis pela administração do programa de proteção da informação.

Papéis e Responsabilidades

. Provedores de Serviço

. Equipe de Operação de Sistemas

- **Devem implementar a segurança técnica nos sistemas;**
- **Em conjunto com o departamento de telecomunicações, devem proteger os serviços de comunicação, incluindo voz, dados, vídeo e fax.**

Papéis e Responsabilidades

. Equipe de Segurança Física

. Equipe de Planejamento de Contingência

- **Devem estabelecer e implementar controles para garantir a segurança física no dia a dia e em situações de emergência ou desastre.**

- **Devem formar um grupo comum para rever e discutir os controles.**

Papéis e Responsabilidades

. Equipe de Metodologia de Desenvolvimento de Aplicações

- **Deve auxiliar na implementação dos requisitos de proteção da informação no ciclo de vida do desenvolvimento do sistema de aplicação.**

Papéis e Responsabilidades

. Equipe de Garantia da Qualidade

- **Deve garantir que os requisitos de proteção da informação estão inclusos em todos os projetos de desenvolvimento antes de passá-los para produção.**

Papéis e Responsabilidades

. Equipe de Apoio Jurídico

- **Deve incorporar as políticas de proteção da informação em acordos e contratos firmados com a organização.**

- **Deve verificar se alguma política de segurança infringe alguma lei da localidade onde a organização ou unidade foi estabelecida.**

Papéis e Responsabilidades

. Equipe de Recursos Humanos

- **Deve organizar treinamentos educativos para desenvolver e implantar programas de conscientização de proteção da informação.**
- **Deve treinar supervisores para capacitá-los a monitorar as atividades de seus subordinados.**
- **Deve tomar a ação adequada diante de violações da política de proteção da informação da organização.**

Papéis e Responsabilidades

. Profissional de Segurança da Informação

- **Desenvolver serviços de segurança da informação para proteger os ativos de informação contra acesso, modificação e destruição não autorizados, com foco particular em:**
  - **Redes Privadas Virtuais**
  - **Privacidade de Dados**
  - **Prevenção de Vírus**
  - **Arquitetura de Aplicações Seguras**
  - **Soluções de Segurança de Provedores de Serviço**

Papéis e Responsabilidades

. Profissional de Segurança da Informação

- **Desenvolver serviços estratégicos de segurança da informação que possam ser adaptados às diversas e mutáveis necessidades tecnológicas dos clientes.**

- **Trabalhar em conjunto com os líderes dos setores de rede e segurança e com consultores, apresentando os requisitos de segurança que atendem as necessidades dos clientes.**

Papéis e Responsabilidades

. Profissional de Segurança da Informação

- **Trabalhar com equipes de implantação de projetos auxiliando na passagem da fase de concepção para a implantação da solução.**

- **Trabalhar com clientes determinando os requisitos de negócio para comércio eletrônico, informando sobre ameaças, vulnerabilidades e estratégias para minimização de riscos.**

Papéis e Responsabilidades

. Profissional de Segurança da Informação

- **Determinar onde e como deve-se utilizar criptografia para prover infraestrutura de chaves públicas e serviços de segurança de mensagens para clientes.**

- **Participar dos grupos de padronização da indústria de segurança para garantir que as necessidades estratégicas de segurança da informação sejam atendidas.**

Ameaças Comuns

Os sistemas de processamento de informação são vulneráveis à várias ameaças e podem implicar em vários tipos de danos resultando em perdas significativas.

- **Danos** vão desde erros que danificam a integridade de bancos de dados até incêndios que destroem complexos inteiros.
- **Perdas** são provocadas pelas ações de empregados supostamente confiáveis, hackers externos, ou pela entrada maliciosa de dados.

Ameaças Comuns

De acordo com o survey "Current and Future Danger: A CSI Primer on Computer Crime & Information Warfare", mais que 80% dos pesquisados apontaram empregados como ameaças ou potenciais ameaças para segurança da informação.

- **O típico criminoso de computadores é um usuário autorizado e não-técnico do sistema que teve oportunidade e tempo suficiente para determinar que ações podem prejudicar o sistema ou causar uma auditoria.**

Ameaças Comuns

A principal ameaça para a proteção da informação ainda está associada a erros e omissões, sendo responsável por 65% dos problemas.

- **Usuários, digitadores de dados, operadores de sistemas, programadores e equivalentes, frequentemente cometem erros que contribuem diretamente ou indiretamente para este problema.**

Ameaças Comuns

Empregados desonestos são responsáveis por 13% dos problemas associados a proteção da informação.

- **Os empregados estão mais familiarizados com os ativos de informação e sistemas de processamento da organização, sabendo quais ações podem causar o maior dano, prejuízo ou sabotagem.**
  - **Destruição de hardware ou facilidades;**
  - **Instalação de códigos maliciosos (vírus, cavalos de tróia, etc);**
  - **Entrada de dados incorretos, remoção e alteração de dados.**

Ameaças Comuns

A perda de facilidades físicas ou da infra-estrutura de suporte levam a sérios problemas e provocam 8% dos problemas relacionados à proteção da informação.

- **Causas típicas:**
  - **Falha de energia, perda de comunicação;**
  - **Vazamento de água, problemas com dutos de esgoto;**
  - **Incêndio, inundação;**
  - **Agitação civil, greves;**
  - **Etc.**

Ameaças Comuns

Ataques de hackers e crakers maliciosos recebem a maior parte da atenção da imprensa, mas são responsáveis por 5% a 8% dos problemas.

- **Embora esses ataques sejam reais e possam causar grandes danos, se os recursos de proteção da informação forem limitados, é melhor concentrar os esforços nos outros problemas.**

- **Para determinar o risco, é importante conduzir uma análise de riscos.**

Gerenciamento de Risco

Risco é a possibilidade de alguma coisa adversa acontecer. O processo de gerenciamento de risco se resume em três etapas:

1. **Identificação dos riscos, ameaças e vulnerabilidades para cada ativo;**
2. **Avaliação da probabilidade desses riscos acontecerem e o impacto que isso terá no ativo ou na organização;**
3. **Determinação dos controles e salvaguardas apropriados para minimizar os riscos a um nível aceitável.**

Gerenciamento de Risco

A principal função do gerenciamento de risco para proteção da informação é a identificação dos controles apropriados, os quais nem sempre são óbvios.

- **O objetivo dos controles não é prover 100% de segurança. Segurança total significa produtividade nula.**
- **Os controles nunca devem perder de vista o objetivo do negócio ou a missão da empresa.**
- **Entre controle e produtividade, a produtividade sempre ganha.**

Gerenciamento de Risco

Para a seleção dos controles apropriados, muitos fatores devem ser observados.

- **Política de proteção da informação da organização;**
- **Legislações e regulamentações que governam a empresa;**
- **Requisitos de segurança, confiabilidade e qualidade;**
- **Requisitos de desempenho:**
  - **Redução no tempo de resposta do usuário;**
  - **Requisitos adicionais para mover aplicação para produção;**
  - **Custos adicionais.**

Gerenciamento de Risco

O custo inicial da implementação dos controles é apenas a ponta do iceberg. Várias outras questões devem ser identificadas.

- **O custo de longo prazo associado a manutenção e monitoramento;**
- **Recursos técnicos necessários para implementação dos controles;**
- **Barreiras culturais.**
  - **Medidas de controle que funcionam e são aceitas em uma localização, podem não ser aceitas em outras.**

Gerenciamento de Risco

O risco residual deve ser aceito. A decisão de manter ou não a operação de um processo ou sistema específico, diante de um risco conhecido, deve ser tomada em algum momento. Muitas razões podem contribuir para aceitação do risco.

- O tipo de risco pode ser diferente de riscos anteriores;
- O risco pode ser técnico e difícil de ser determinado por uma pessoa leiga;
- O próprio ambiente pode dificultar a identificação do risco.

Gerenciamento de Risco

Profissionais de proteção da informação devem ter em mente que os gerentes são contratados para tomar decisões. É perfeitamente permissível que, a critério próprio, um gerente aceite um risco.

- **O trabalho do Profissional de Segurança da Informação deve focar em:**
  - **Ajudar o responsável pela informação a identificar riscos associados a esse ativo;**
  - **Auxiliar o responsável pela informação na identificação dos possíveis controles;**
  - **Permitir que o responsável pela informação determine seu plano de ação.**

Classificação da Informação

As empresas classificam as informações para estabelecer os níveis de proteção apropriados para cada categoria. Devido à limitação de recursos, é necessário priorizar e identificar o que realmente requer proteção.

- **O processo de classificação da informação é um processo de decisão de negócios e requer o papel ativo do setor gerencial da empresa.**
- **Os profissionais de segurança e os técnicos de computadores exercem papéis limitados nesse processo.**

Classificação da Informação

A informação que requer proteção tipicamente se enquadra em um ou mais dos seguintes quesitos:

- **Tem algum valor para a empresa e seus competidores, caracterizando uma vantagem competitiva;**
- **É resultado de algum tipo de gasto ou investimento feito pela empresa;**
- **É, de alguma forma, única e não é de conhecimento geral da indústria ou do público.**

Classificação da Informação

Tipicamente, três categorias são utilizadas para classificar a informação:

1. **Confidencial (Sensível, Pessoal, Privilegiada)**
   - Se for exposta, viola a privacidade de indivíduos, reduz a vantagem competitiva da empresa ou causa danos a mesma.
     - Registros pessoais e informações de clientes;
     - Informações sobre custo, lucro e resultado financeiro;
     - Planos operacionais e estratégias de marketing e negócios;
     - Requisitos de mercado, tecnologias, planos de produtos.

Classificação da Informação

Tipicamente, três categorias são utilizadas para classificar a informação (continuação):

2. Restrita (Uso Interno)

- Informação destinada ao uso de funcionários na condução dos negócios da empresa.
  - Relatórios e informações sobre a operação do negócio;
  - Informações que pertencem a parceiros de negócios e que são protegidas por acordos de restrição de exposição;
  - Lista telefônica da empresa;
  - Políticas, padrões e procedimentos corporativos.

Classificação da Informação

Tipicamente, três categorias são utilizadas para classificar a informação (continuação):

3. Pública (Não Classificada)

- Informação que foi disponibilizada para distribuição pública através de canais da empresa devidamente autorizados, não requerendo proteção.
  - Relatório anual da empresa;
  - Boletins de serviço público;
  - Apresentações de marketing;
  - Propaganda.

Políticas e Procedimentos

Política de proteção da informação é a documentação que espelha as decisões da empresa com respeito à manipulação e proteção da informação. Os pontos chaves são:

- **A informação é um ativo da empresa e é propriedade da organização.**
- **A informação vai além dos limites de TI e está presente em todas as áreas da empresa.**
- **A política de segurança da informação deve ser parte do programa de gerenciamento de ativos da organização para ser efetivo.**

Políticas e Procedimentos

Toda organização precisa de uma política de proteção da informação. O início de um programa é determinado pela implementação de uma política.

- **A política do programa cria uma atitude da organização em relação à informação e anuncia internamente e externamente que a informação é um ativo e propriedade da organização que deve ser protegido contra acesso, modificação, revelação e destruição não autorizados.**

Políticas e Procedimentos

Políticas não são suficientes. Outras ações são necessárias para garantir a prática das políticas.

- **Desenvolvimento de normas que definam os códigos de práticas para padronizar os requisitos para certificações.**
- **Definição de procedimentos e linhas de ação capazes de implantar a prática da proteção da informação.**
- **Instauração de auditorias periódicas para validar a conformidade da empresa com os padrões adotados.**